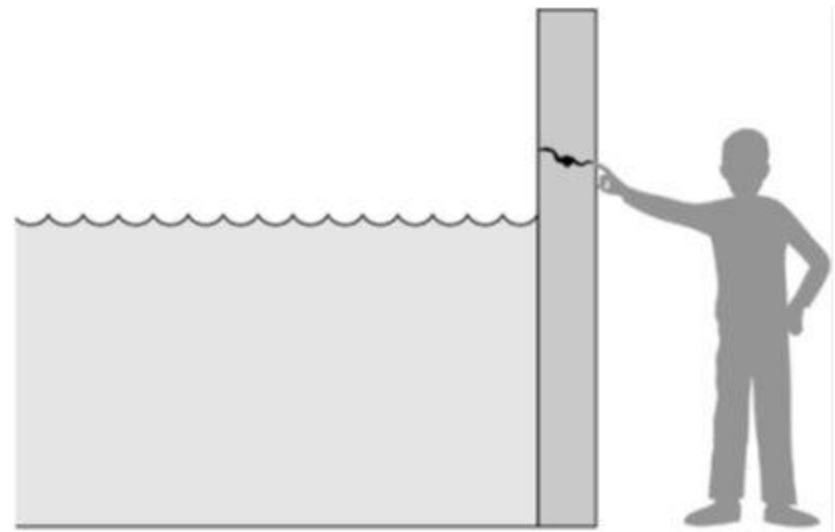
What is Threat and Vulnerability?

Example

The water flowing to the right is a threat to the man (he might catch a cold)
Example: The existence of a particular virus



The crack in the wall is a vulnerability
Example: Open ports on a computer

Vulnerability + Threat = Risk!

bmc

Threat

A new incident with potential to harm a system

+

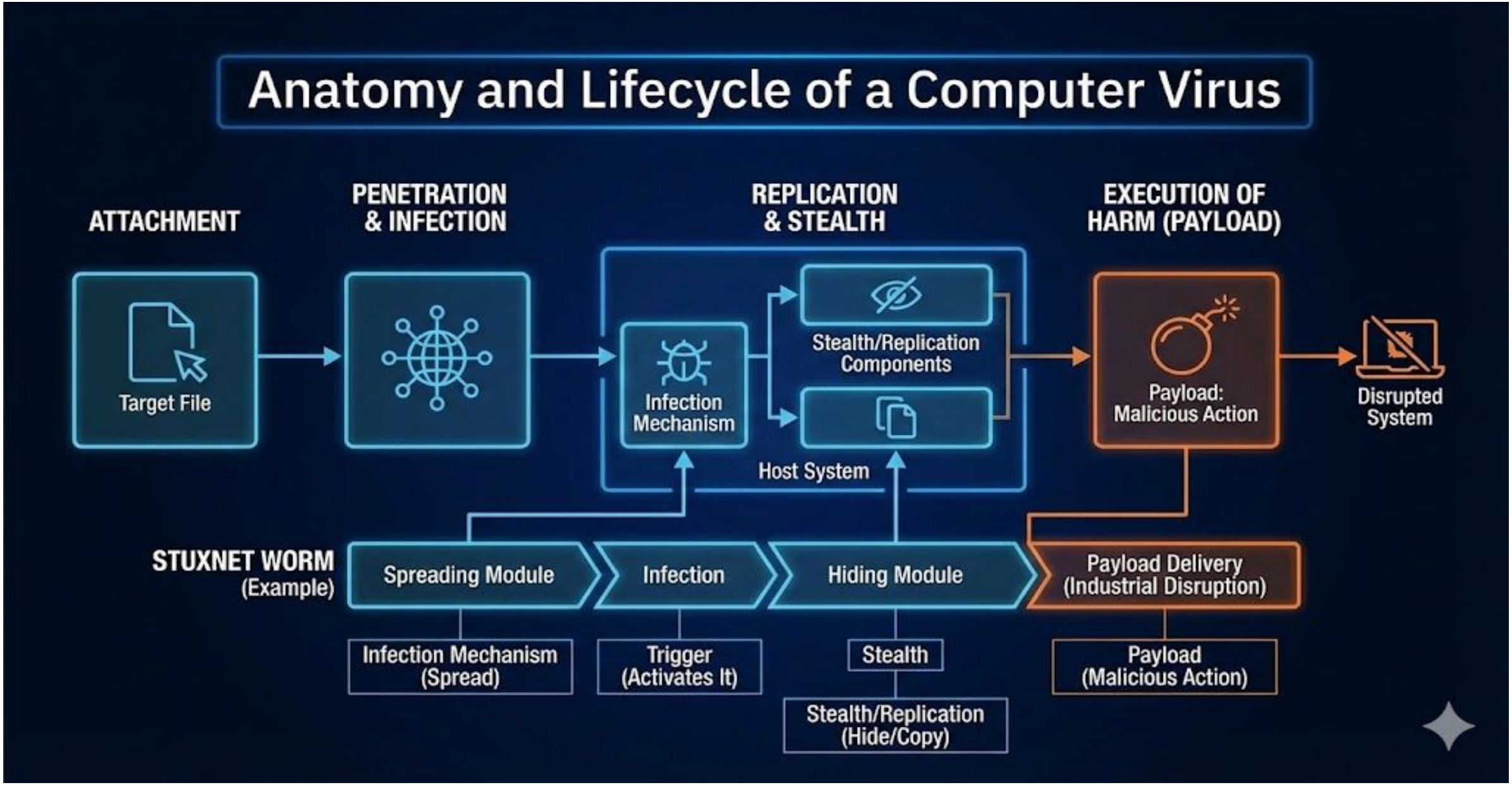
Vulnerability

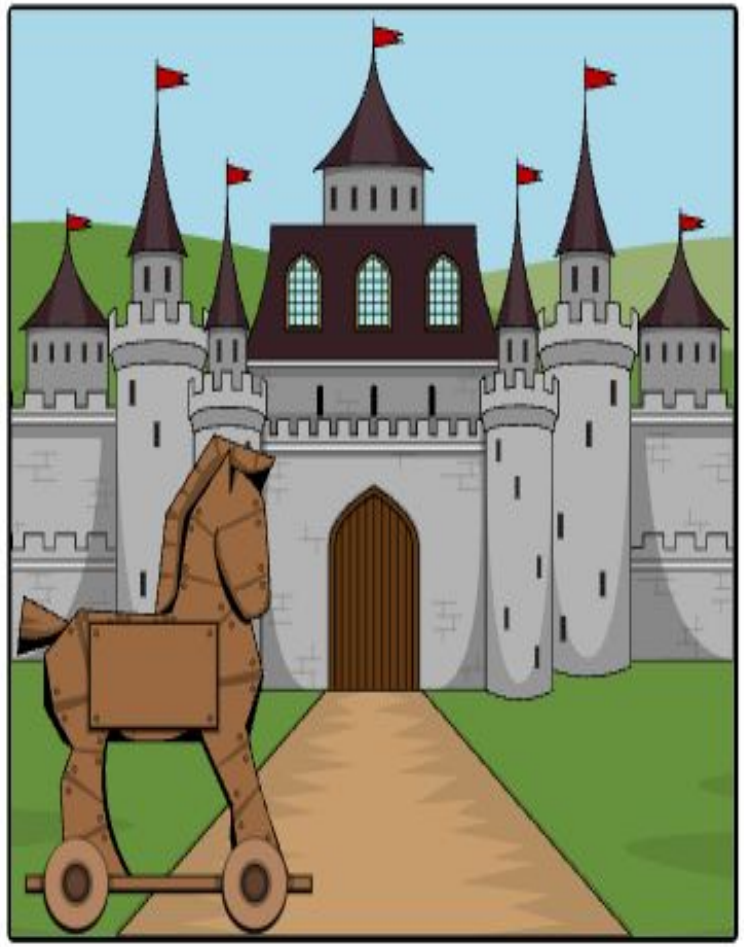
Known weakness that hackers could exploit

=

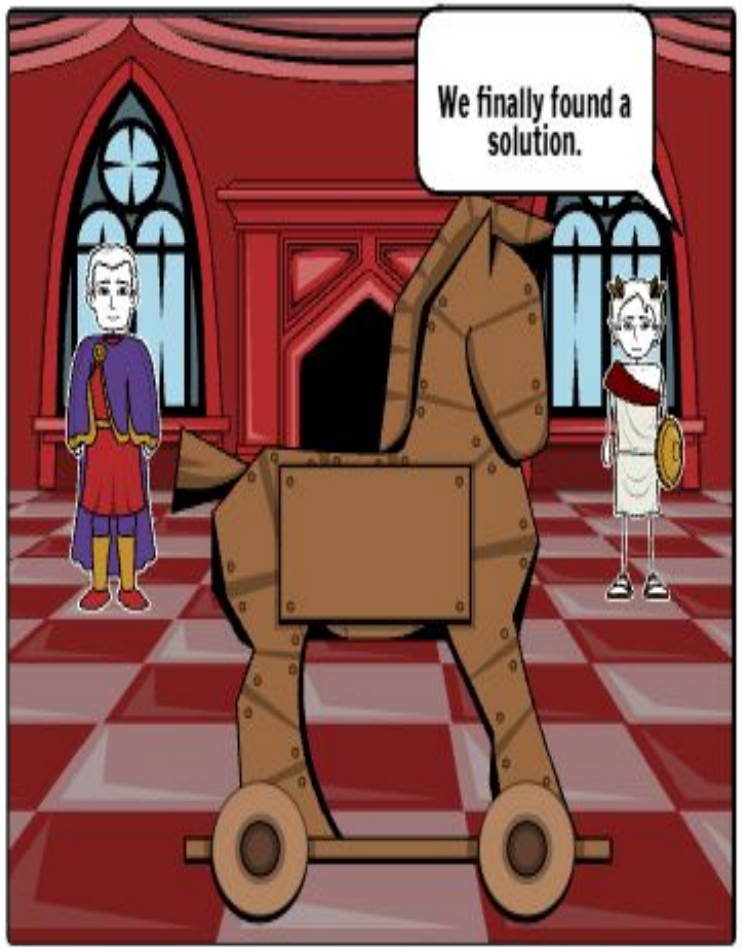
Risk

The potential for damage when a threat exploits a vulnerability

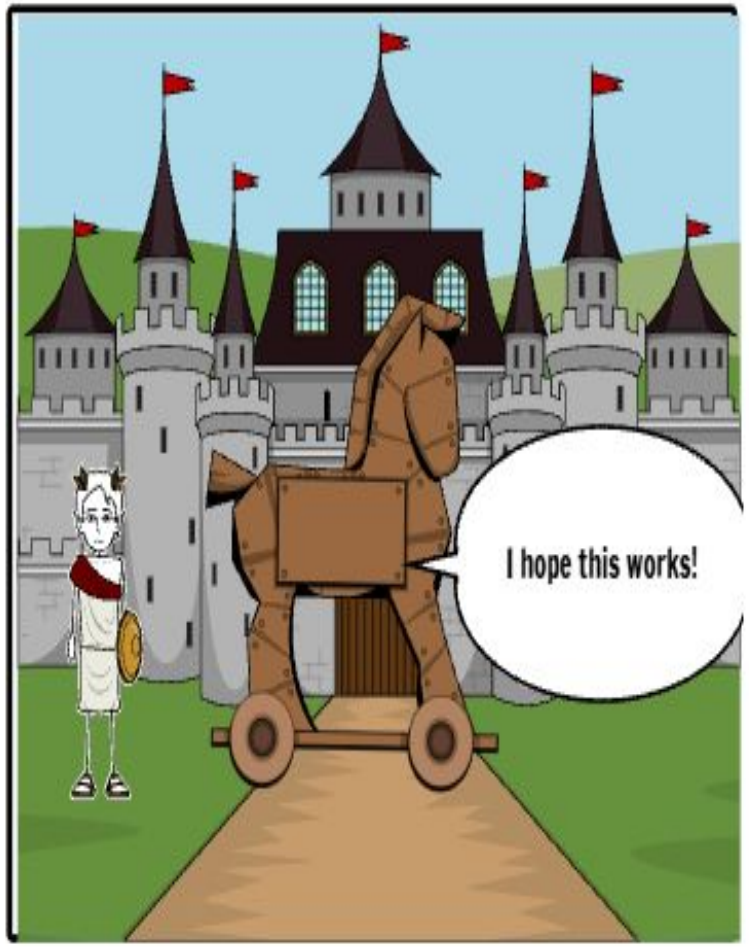

Anatomy and Lifecycle of a Computer Virus
ATTACHMENT
PENETRATION & INFECTION
REPLICATION & STEALTH
EXECUTION OF HARM (PAYLOAD)
Target File
Infection Mechanism
Stealth/Replication Components
Host System
Payload: Malicious Action
Disrupted System
STUXNET WORM (Example)
Spreading Module
Infection
Hiding Module
Payload Delivery (Industrial Disruption)
Infection Mechanism (Spread)
Trigger (Activates It)
Stealth
Stealth/Replication (Hide/Copy)
Payload (Malicious Action)



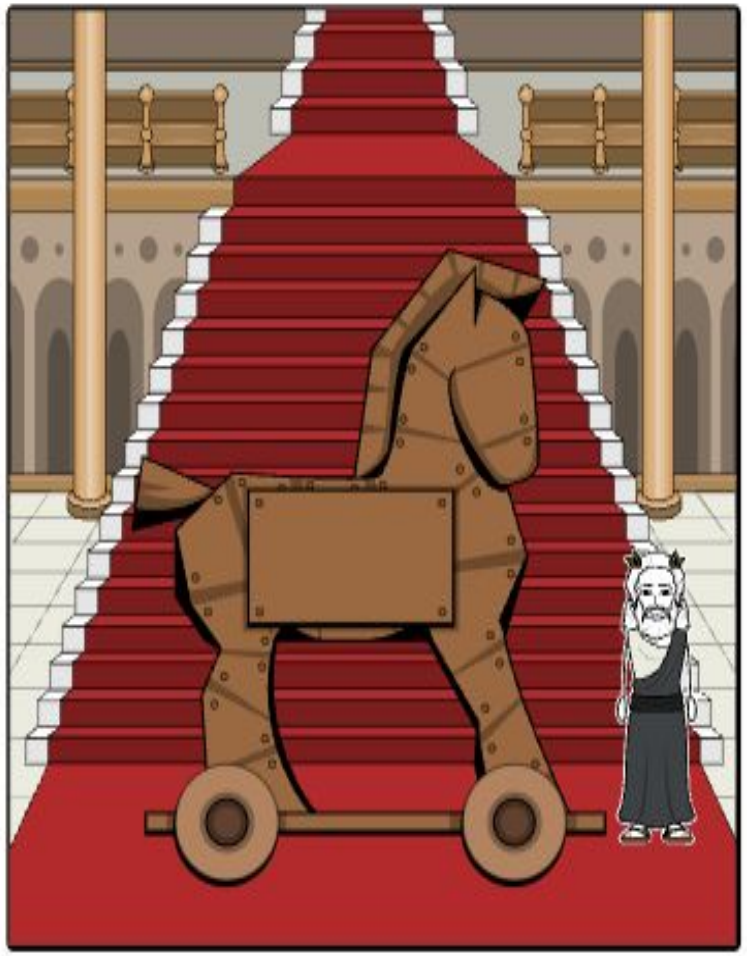
It was toward the end of the Trojan War between the Greeks and the Trojans. The Greeks finally found a way into Troy and get the princess back.



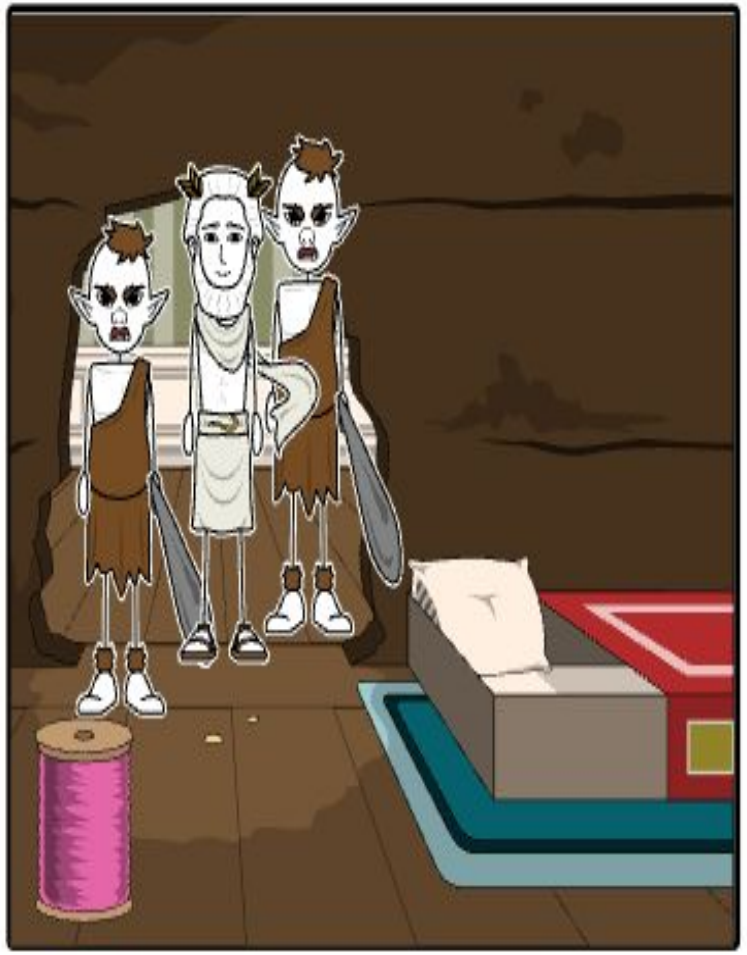
The Greeks created a large hollow wooden horse and persuaded the Trojans that it was an offering to the goddess Athena.



The Greeks sent the horse in with many soldiers inside.

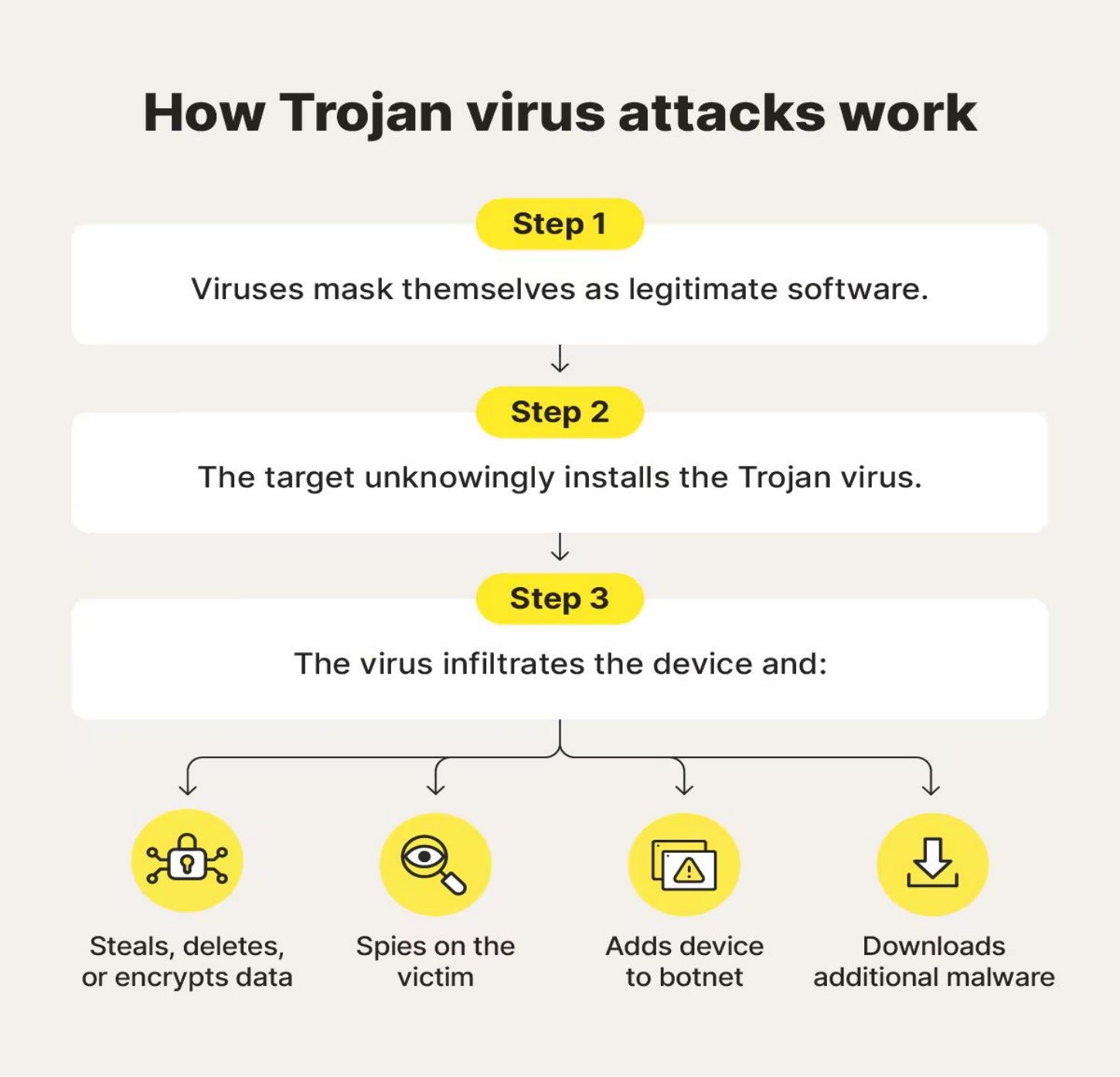


The Trojans gladly took the horse and thought that the Greeks had surrendered.



That night when the Trojans went to sleep, the Greek soldiers came out of the horse and slaughtered the Trojans.

The Greeks won the war and got back their princess.



Trojan Horse

Examples of Trojan Horse viruses include:

- **Zeus Trojan:** It steals banking information from the user's computer
- **Back Orifice Trojan:** It allows a remote attacker to take control of the infected computer.

Computer Worms	Computer Viruses	Trojan Horses
1. Can self-replicate 2. They do not need to attach themselves with existing programs	1. Can self-replicate 2. Attach themselves with existing programs	1. Cannot self-replicate 2. Use social engineering techniques to spread.

The Security Buddy

The Security Buddy
https://www.thesecuritybuddy.com/

Feature	Virus	Worm	Trojan
How it Works	**Attaches to a host:** It embeds itself in a legitimate program or file and activates when that file is executed.	**Standalone program:** It exists independently and does not need a host file to run or replicate.	**Disguise/Decoy:** It pretends to be legitimate, useful software (like a game or utility) to trick the user into installing it.
Spread Mechanism	**User Action Required:** Spreads only when a user interacts with it (e.g., opening an attachment, running an infected EXE).	**Automatic:** Exploits network vulnerabilities to spread automatically across systems without user intervention.	**Deception:** Spreads via social engineering (deceptive downloads, email links); it **does not** self-replicate.
Primary Function	**Data Damage:** Focuses on damaging, corrupting, or altering files and data on the specific infected machine.	**Resource Consumption:** Consumes system resources (RAM, CPU) and network bandwidth, often causing slowdowns or crashes.	**Access & Theft:** Creates "backdoors" for attackers to steal sensitive data or take remote control of the system.

Image used for respresentational purpose only.

From our online archive

Updated on: 31 May 2018, 11:29 pm · 3 min read

Add TNIE As A Trusted Source

Add as a preferred source on Google

New Delhi, May 31 (PTI) Two social media-triggered spyware viruses -- 'virtual girlfriend' and 'panda banker' -- have creeped into the Indian cyberspace and can steal a user's banking details and secret data once activated unknowingly, a cybersecurity advisory has said.

The more notorious one is personal data-stealing virus 'virtual girlfriend' that "infects" a user's Android-based smartphone via popular social media site Twitter.

Related Stories

After Lok Sabha, Upper House clears bill to levy cess on pan masala units

Parvez Sultan · 57 minutes ago

SC to hear review plea on ISKCON Temple on January 22

Suchitra Kalyan Mohanty · 1 hour ago

Goa nightclub fire: Probe panel told to submit report within 7 days

Sudhir Suryawanshi · 1 hour ago

Lucknow Diary | Monk returns for SIR documents after 36 yrs

Namita Bajpai · 1 hour ago

Similarly, the other spyware that has been noticed on the Internet is the 'panda banker', a spin-off of the zeus banking trojan malware (a prominent hacking virus).

"It leverages man-in-the-browser or web inject attack techniques to steal user's banking credentials," the advisory said.

The malware, it said, generally spreads via unscrupulous attachments or via exploit kits (malicious snooping virus programmes) such as "ngler", "nuclear" and "neutrino" exploit kits.

"Though the prime-targeted sector of this malware is financial sector and cryptocurrency sites, it also expands its attack in different organisation sectors like social networking sites, search, e-mail and adults sites," it said.

Once successfully installed, this virus starts analysing the victim's system to get information such as the name of anti-virus, computer name, spyware installed, username, local time, among others, and sends this data to the C2 server, it said.

Three-type classification of insider threats

Malicious insiders

Intentionally use their access to sensitive data to harm the company

Careless insiders

Pose an unintentional threat due to human error or security policy violations

Compromised insiders

Insiders whose accounts are compromised and used by cyber criminals

EKRAN.
www.ekransystem.com

Types Of Attacks

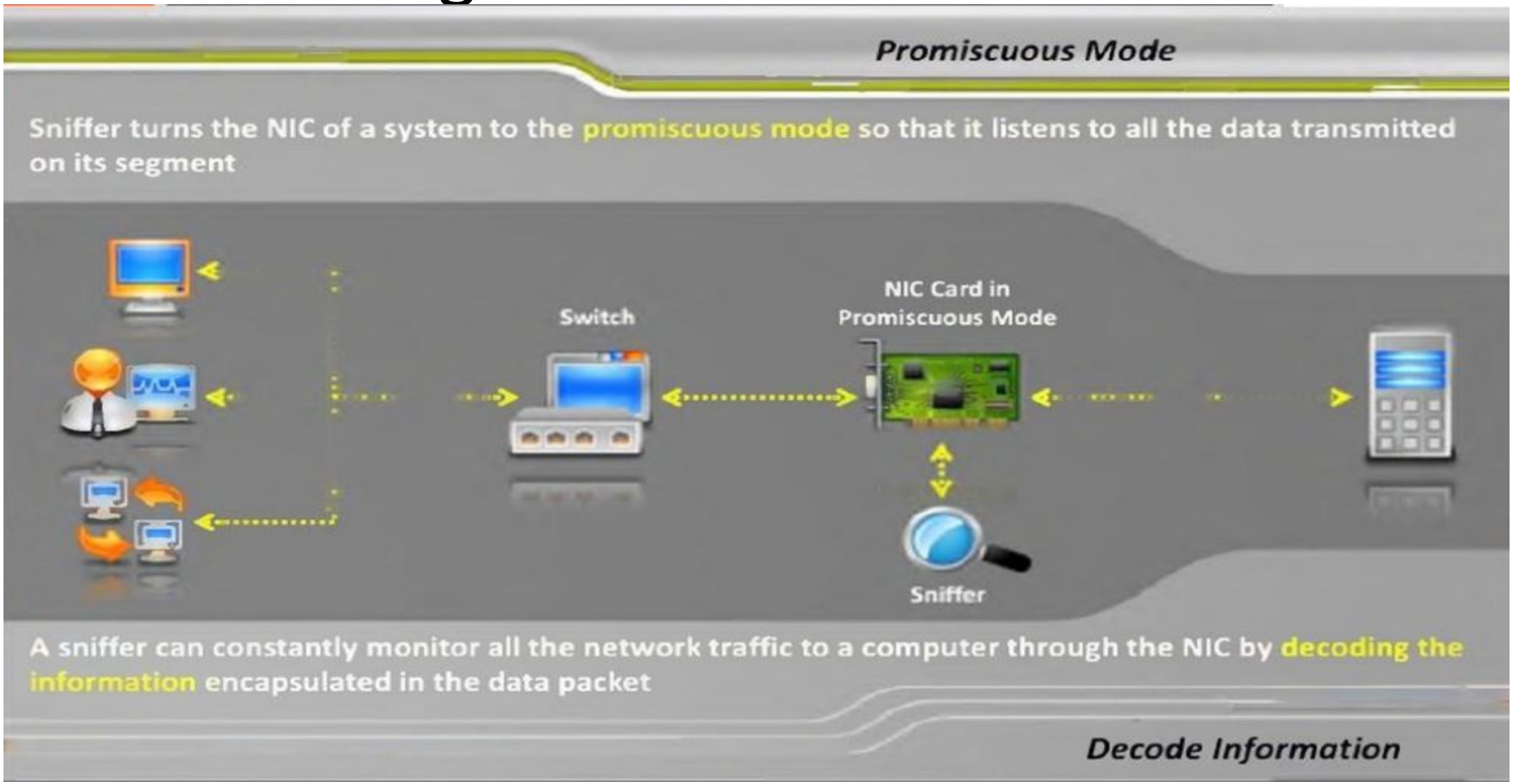
Physical Attacks	Network Layer Attacks	Application Layer Attacks	Man In Middle Attacks
• Keystroke logging • Steal data	• Packet sniffing • Protocol Anomaly	• Content • Buffer Overflow • Password Cracking • P2P	• ARP Poisoning • MAC flooding • DHCP poisoning • DNS spoofing • ICMP poisoning • Wireless attacks

- A **patch** is a piece of software code that can be applied after the software program is installed to correct an issue with that program. Most software programs may have several patches after their initial release and usually update the version of the program when installed.

DDOS:

You check your GPS traffic report, only to see that the jam extends for miles and there's no way around it. There's no way you'll make it to the park in time for your picnic

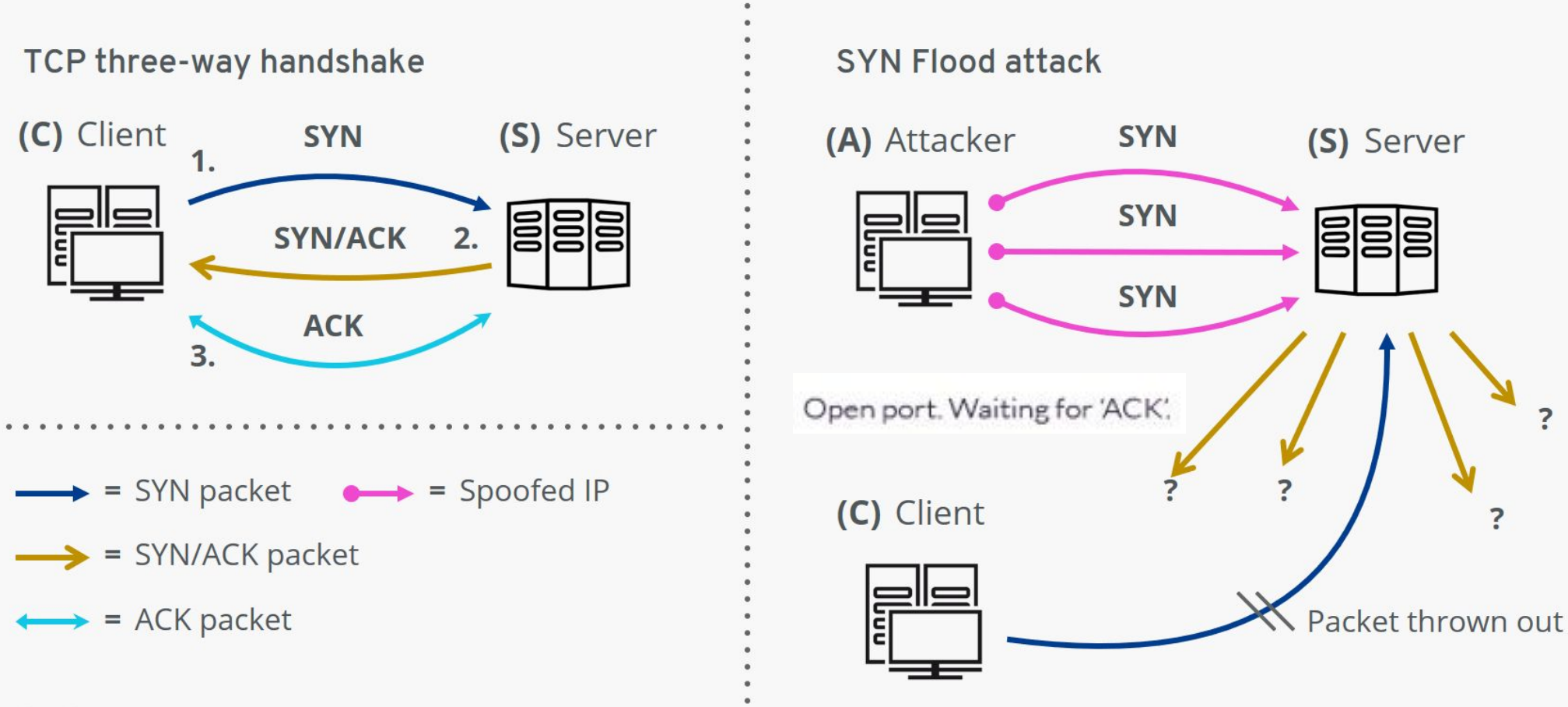
Packet Sniffing



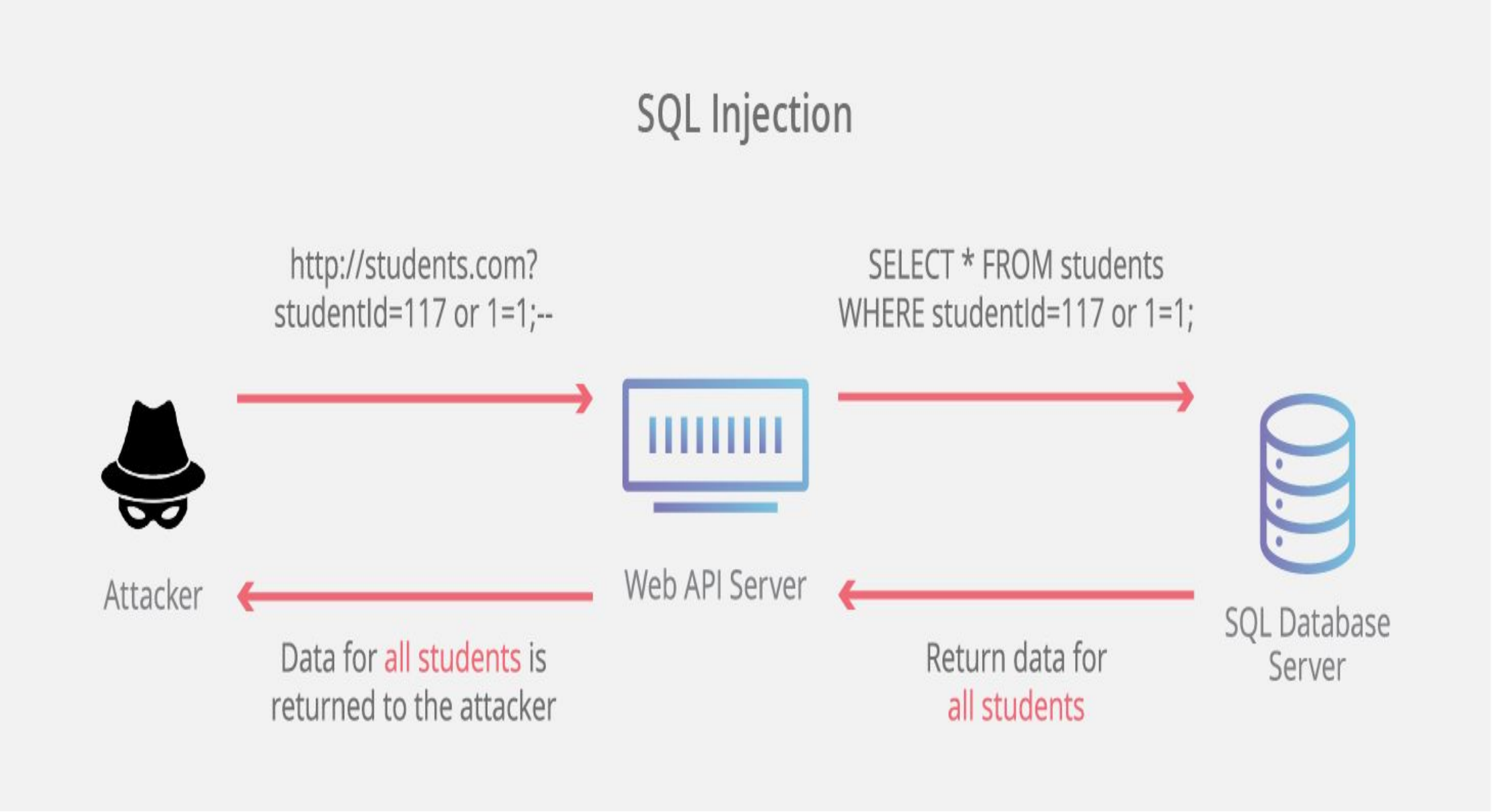
Note: In a network, **promiscuous mode** allows a network device to intercept and read each network packet that arrives in its entirety.

SYN Flood

How it works

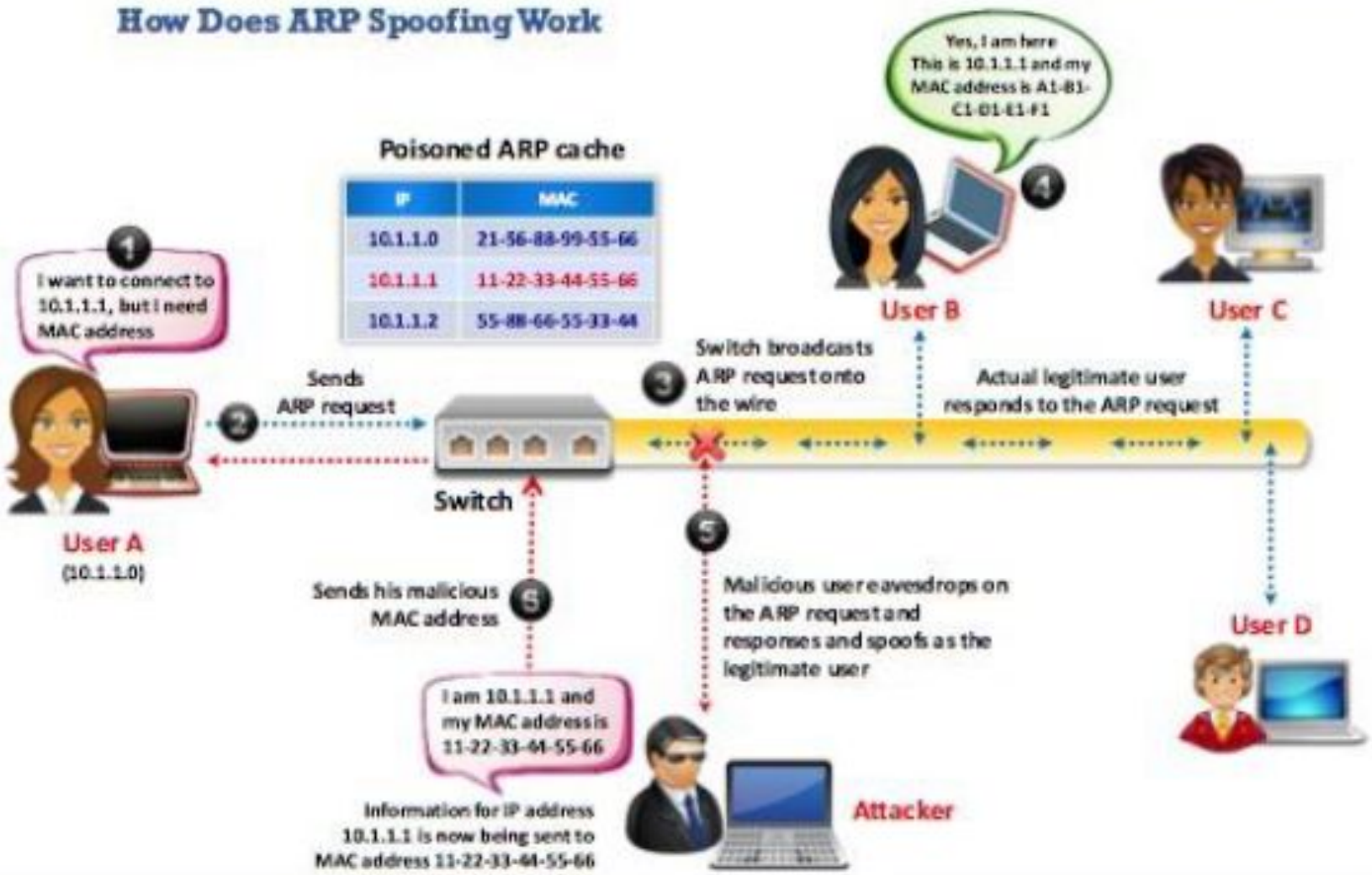


IONOS


SQL Injection
http://students.com?
studentId=117 or 1=1;--
SELECT * FROM students
WHERE studentId=117 or 1=1;
Attacker
Web API Server
SQL Database
Server
Data for all students is
returned to the attacker
Return data for
all students

ARP Spoofing Attack

- ARP packets can be **forged** to send data to the attacker's machine
- ARP Spoofing involves constructing a large number of **forged ARP request** and reply packets to overload a switch
- Switch is set in **'forwarding mode'** after ARP table is flooded with spoofed ARP replies and attackers can sniff all the network packets
- Attackers flood a target computer's ARP cache with forged entries, which is also known as **poisoning**



Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Password Cracking Techniques

DEFINITIONS

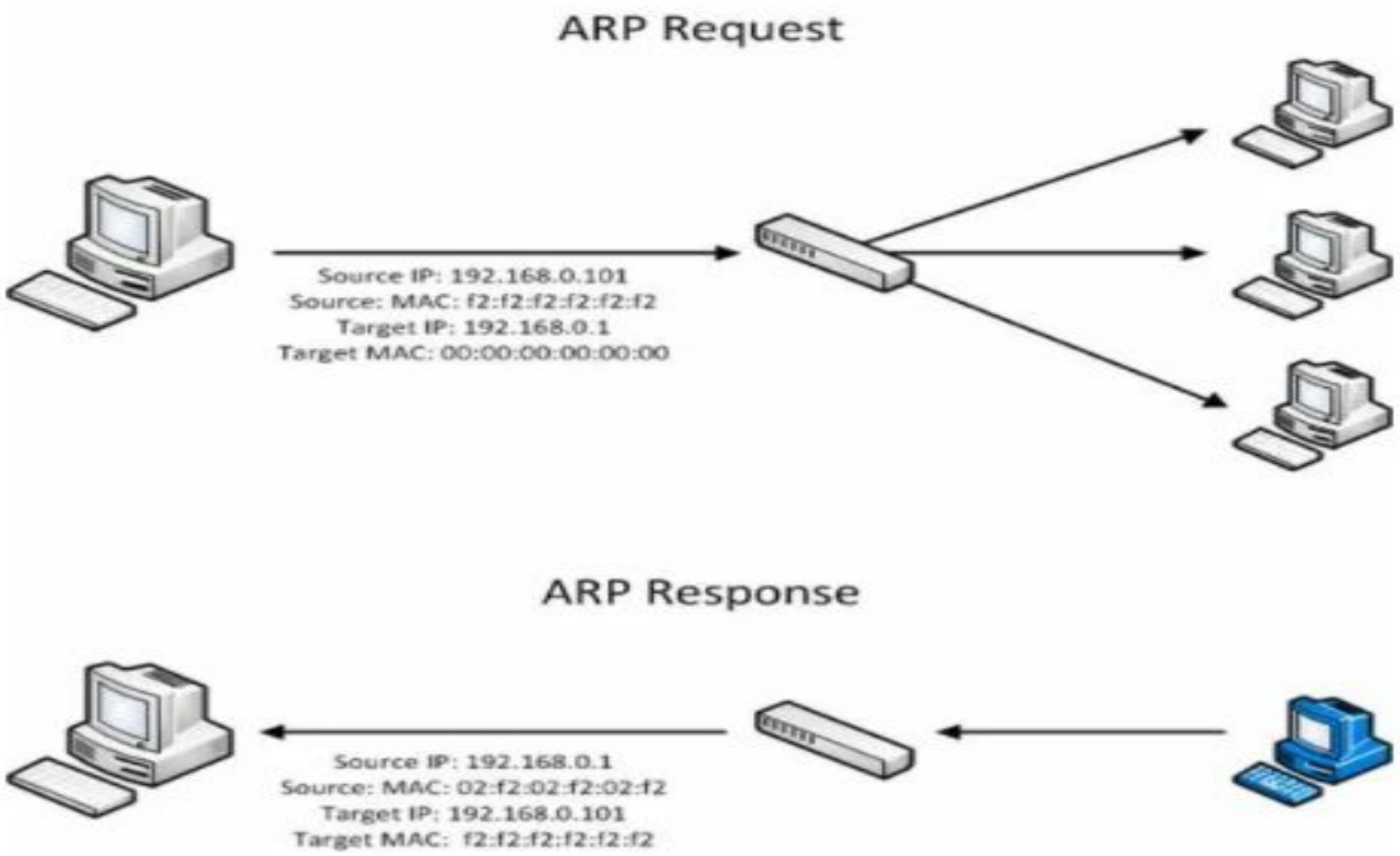
- A **dictionary attack** uses a word list file, which is a list of potential passwords.
- A **brute-force attack** is when the attacker tries every possible combination of characters.
- A **hybrid attack** builds on the dictionary attack method by adding numerals and symbols to dictionary words

How to Defend Against Brute Force Attacks

- Increase password length
- Increase password complexity
- Limit login attempts
- Implement Captcha
- Use multi-factor authentication

VARONIS

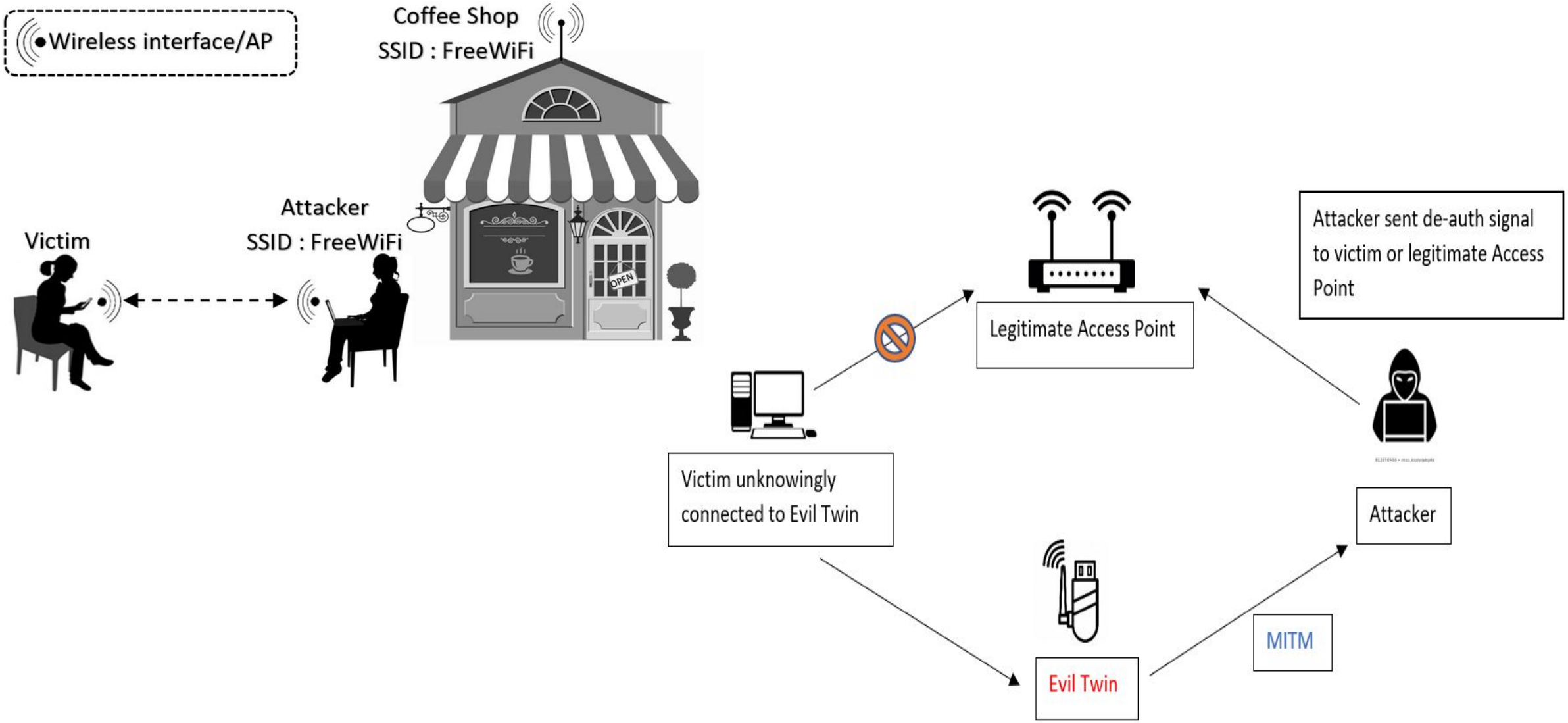
ARP Communication



```
C:\Users\Nakshatra>arp -a

Interface: 192.168.1.102 --- 0x12
  Internet Address      Physical Address      Type
  192.168.1.1           38-6b-1c-71-a1-aa     dynamic
  192.168.1.100         1a-f0-6b-2c-47-91     dynamic
  192.168.1.254         00-1e-a6-66-97-20     dynamic
  224.0.0.2             01-00-5e-00-00-02     static
  224.0.0.22            01-00-5e-00-00-16     static
  224.0.0.251           01-00-5e-00-00-fb     static
  224.0.0.252           01-00-5e-00-00-fc     static
  239.255.102.18        01-00-5e-7f-66-12     static
  239.255.255.250       01-00-5e-7f-ff-fa     static
```

Wireless Attack : Evil Twin



The attacker can successfully lure a victim into connecting to a fake access point instead of the legitimate access point <u>when it provides a stronger/better signal to those customers.</u>

Example: Risk Assessment Matrix

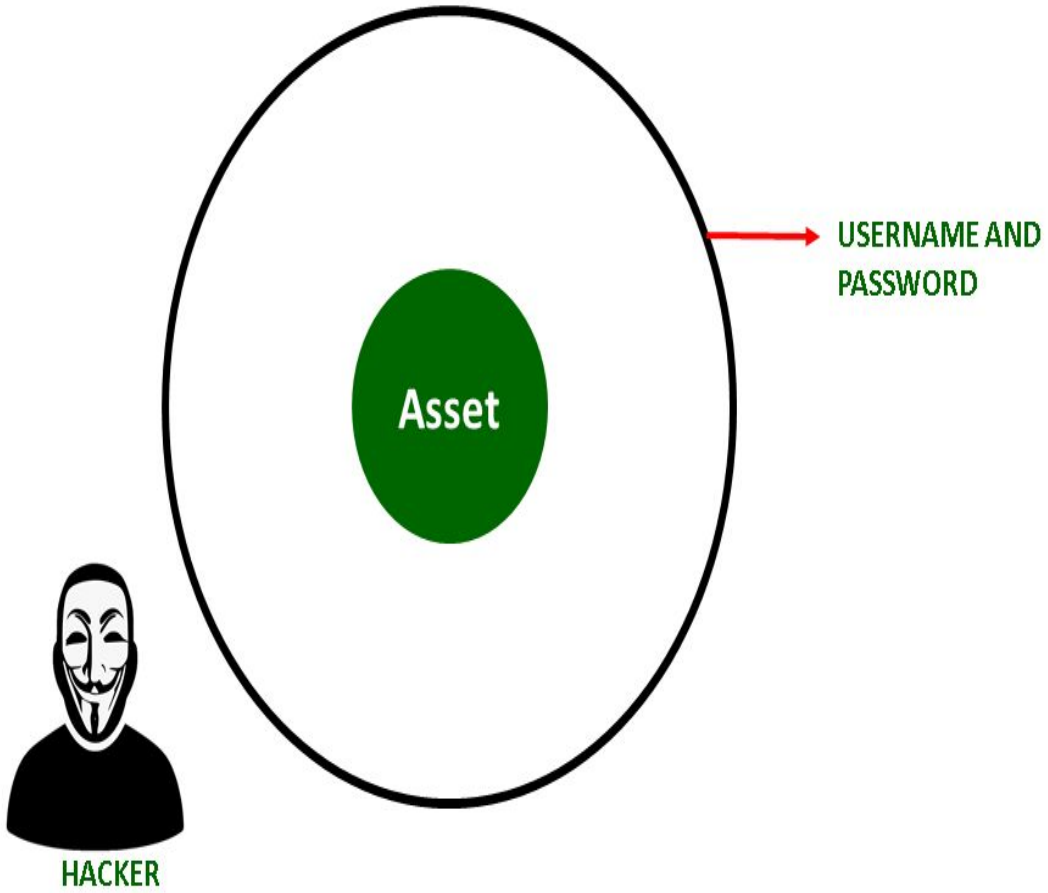
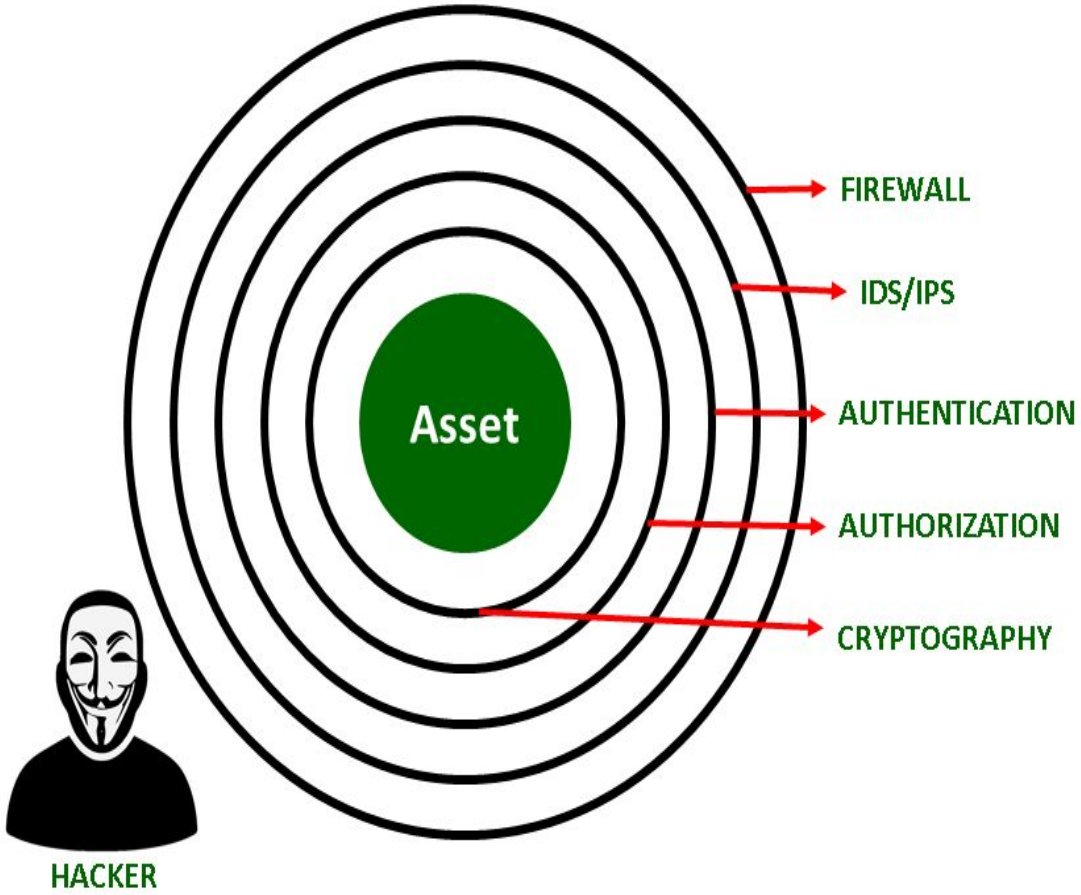
Cisco.com

System	Description	Risk Level	Types of Users
Network switches	Core network device	High	Administrators All others for use as a transport
Network routers	Edge network device	High	Administrators All others for use as a transport
Closet switches	Access network device	Medium	Administrators All others for use as a transport
ISDN or dial-up servers	Access network device	Medium	Administrators Partners and privileged users for special access
Firewall	Access network device	High	Administrators All others for use as a transport
DNS and DHCP servers	Network applications	Medium	Administrators General and privileged users for use
Internal e-mail server	Network application	Medium	Administrators All other internal users for use
Oracle database	Network application	Medium or High	Administrators Privileged users for data updates General users for data access All others for partial data access

MyShared

© 2004 Cisco Systems, Inc. All rights reserved.

LOLLIPOP MODEL



ONION MODEL